



BUILDING A SIEM ENVIRONMENT TO DETECT CREDENTIAL DUMPING

LSASS Memory Dump-T1003.001



APRIL 15, 2025

Group No: 1

ABDULLAHI MOHAMED (100962112)

DAVID USMAN (100957847)

MADHVI LASHKAREE (100997946)

SEAN LACY (101002424)

Contents

Objective 2

Wazuh SIEM tools 2

Attack simulation framework 3

Architecture diagram 4

Methodology 5

Summary: 14

References: 14

Objective

The objective of this project is to build and configure a Security Information and Event Management (SIEM) environment using Wazuh to detect and analyze Credential Dumping attacks via LSASS Memory Dump (MITRE ATT&CK ID: T1003.006). The project will involve simulating this specific attack using the Invoke-Atomic framework and monitoring the generated alerts in the Wazuh dashboard.

Wazuh SIEM tools

Wazuh is a free and open-source Security Information and Event Management (SIEM) tool. It is used to monitor systems for security threats, detect intrusions, ensure compliance with security standards, and analyze system activity through log collection and threat detection. It helps organizations by collecting data from multiple sources, analyzing it for potential threats, and alerting security teams when suspicious activities are detected.

Core Components of Wazuh

1. **Wazuh Agent:** Installed on endpoints (such as Windows, Linux, or macOS systems), the agent collects system logs, monitors files for changes, and detects suspicious activities.
2. **Wazuh Manager:** This is the central component that receives data from agents, analyzes it using predefined rules, and generates security alerts.
3. **Elasticsearch:** Acts as the storage and search engine for logs and alerts. It indexes the data to make it easy to search and analyze.
4. **Kibana with Wazuh Plugin:** A web-based interface used to visualize logs, alerts, and other security data. It provides dashboards and tools for deeper investigation and analysis.

How Wazuh Works

1. **Data Collection:** Wazuh agents installed on endpoints collect logs and security data.
2. **Data Forwarding:** The collected data is sent to the Wazuh Manager.
3. **Analysis:** The Manager processes the data using built-in detection rules to identify suspicious behavior or known attack techniques.
4. **Alert Generation:** If a match is found with any rule (e.g., signs of a credential dumping attack), an alert is created.
5. **Data Storage:** All data, including alerts and logs, is stored in Elasticsearch for indexing and fast retrieval.
6. **Visualization and Investigation:** Security analysts use Kibana to view alerts, search logs, and investigate incidents through dashboards and queries.

Key Features of Wazuh

- Real-time detection of threats and attacks
- Centralized log management

- File integrity monitoring
- Intrusion detection system (IDS) capabilities
- Compliance monitoring (e.g., HIPAA, PCI-DSS)
- Integration with MITRE ATT&CK framework
- Customizable rules and alerting

Attack simulation framework

The MITRE ATT&CK Framework is a globally accessible knowledge base of real-world Tactics, Techniques, and Procedures (TTPs) used by cyber adversaries. It is widely used by red teams to simulate realistic attacks and by blue teams to develop effective detection and defense mechanisms. Each technique within the framework is assigned a unique ID, such as T1003.001 for LSASS memory dumping.

Atomic Red Team is an open-source project that provides small, independent tests known as *atomic tests* for each technique in the MITRE ATT&CK framework. These tests are designed to be simple, reproducible, and safe to run in a controlled lab environment. They help cybersecurity professionals validate their detection capabilities against known attack behaviors.

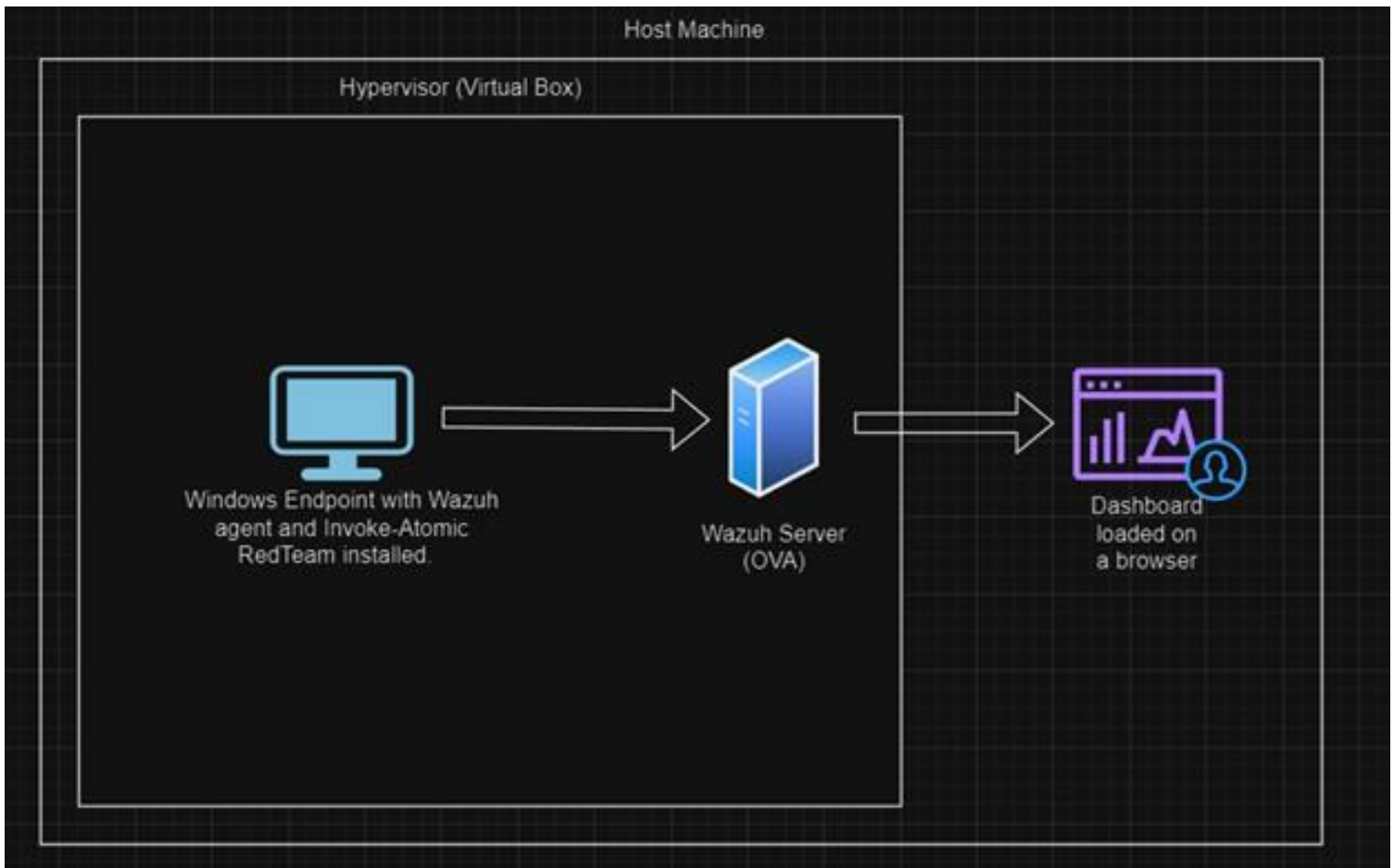
Invoke-Atomic is a PowerShell module that allows users to easily run Atomic Red Team tests on Windows systems. It automates the process of downloading and executing atomic tests, making it easier for security teams to simulate specific attacks and evaluate their system's response and visibility.

One of the techniques documented in the MITRE ATT&CK framework is Credential Dumping, specifically through LSASS (Local Security Authority Subsystem Service) memory dumping, identified as T1003.001. In this method, an attacker attempts to extract user credentials by accessing the memory space of LSASS, which stores sensitive authentication data.

In this project, the Invoke-Atomic module is used to simulate this attack technique in a lab setup. The goal is to generate realistic alerts in a Wazuh SIEM environment and analyze the detection capabilities for T1003.001.

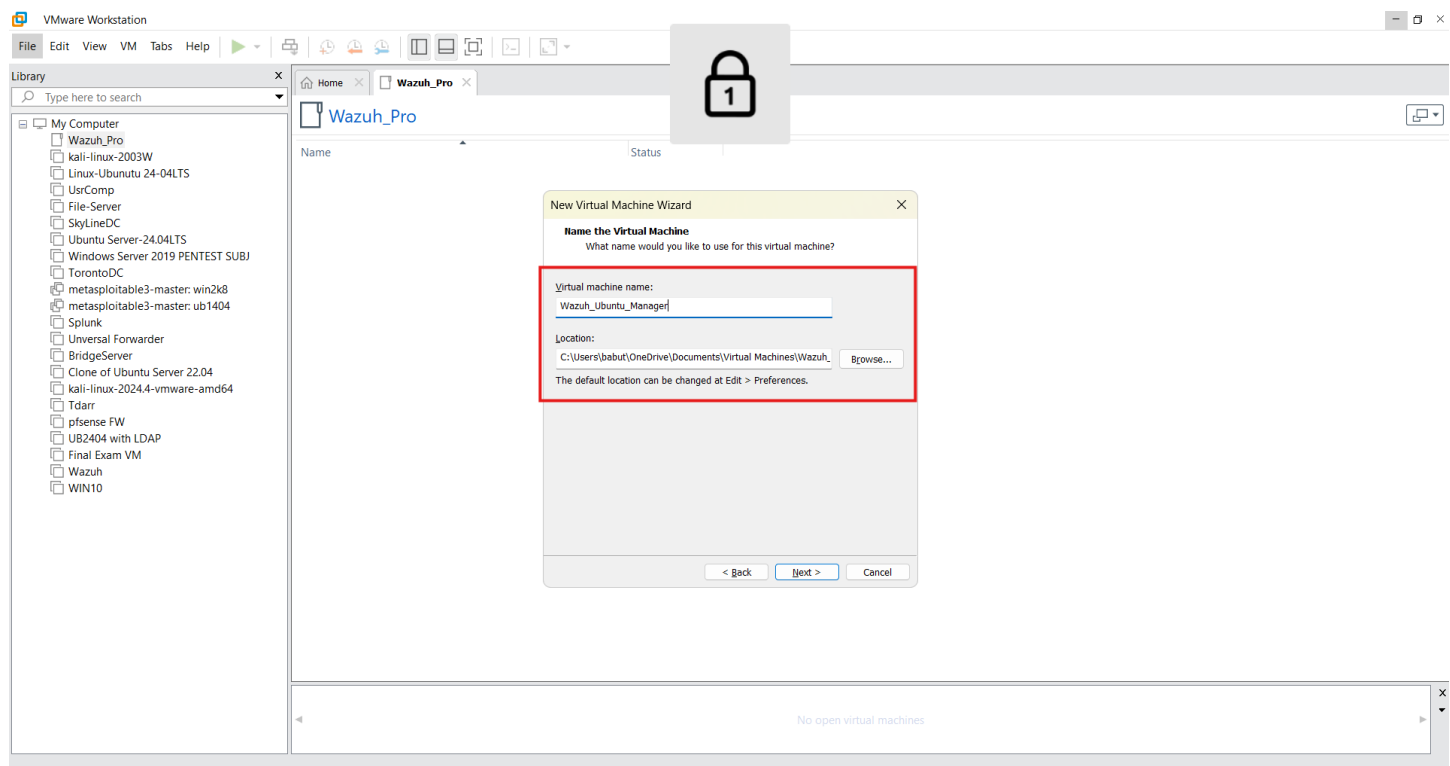
Architecture diagram

Inside the virtual environment, three main components work together: a Windows computer with Wazuh agent and Invoke-Atomic RedTeam tools installed, a central Wazuh Server and a web-based Dashboard. The Windows machine generates security events and can simulate attacks, sending this data to the Wazuh Server which processes and analyzes it. Security team can then view the results through graphs and alerts on the Dashboard accessed via a web browser. This setup allows security teams to monitor system activities, test defense mechanisms, and practice detecting threats without risking real production systems.

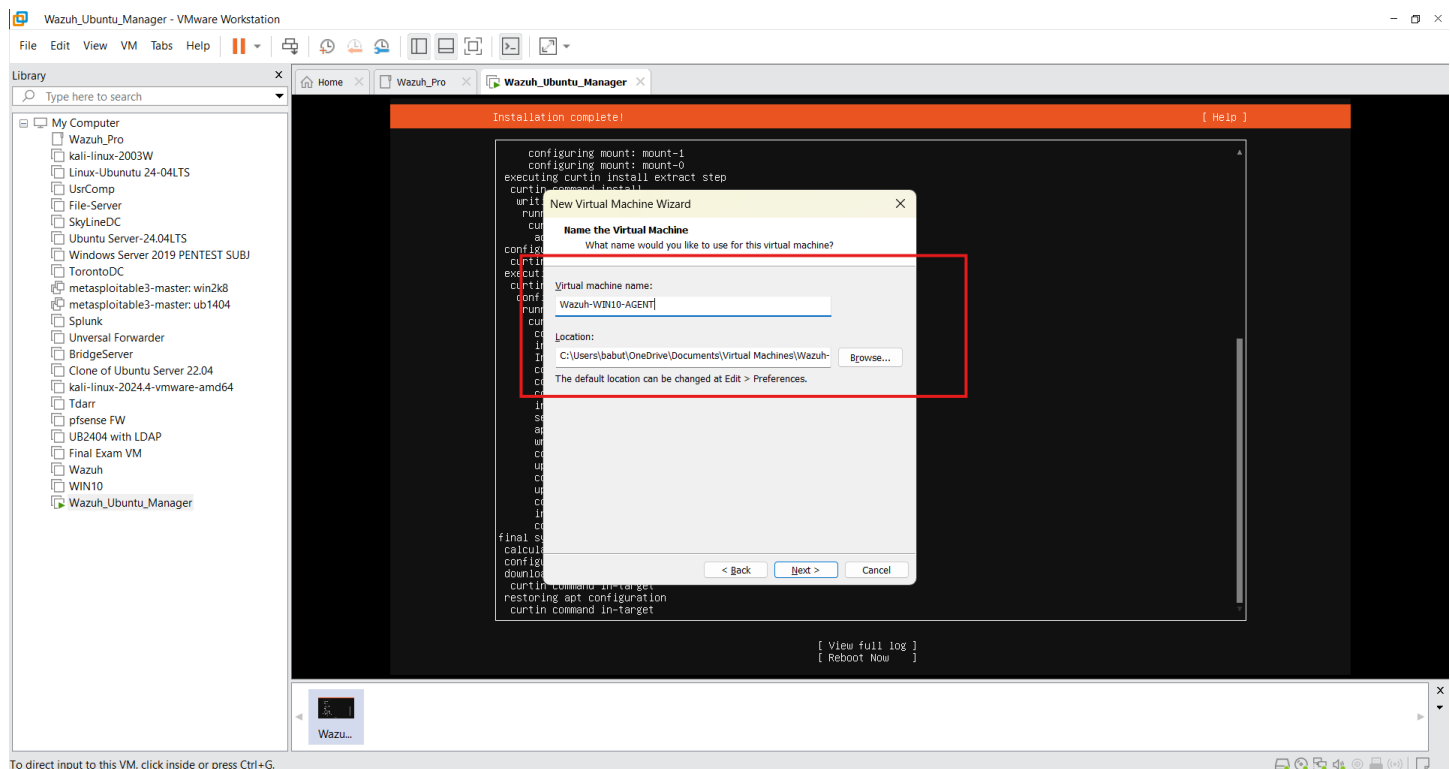


Methodology

1. Install Ubuntu using the ISO ubuntu-22.04.5-desktop-amd64.iso on a virtual machine.



2. Install Windows on a separate virtual machine.



3. In Ubuntu, open Terminal and run the command: **sudo apt update**

```
Wazuh manager
wazuhadmin@wazuhmanager:~$ sudo apt update
[sudo] password for wazuhadmin:
Hit:1 http://ca.archive.ubuntu.com/ubuntu jammy InRelease
Hit:2 http://ca.archive.ubuntu.com/ubuntu jammy-updates InRelease
Hit:3 http://security.ubuntu.com/ubuntu jammy-security InRelease
Hit:4 http://ca.archive.ubuntu.com/ubuntu jammy-backports InRelease
Reading package lists... Done
Building dependency tree... Done
Reading state information... Done
53 packages can be upgraded. Run 'apt list --upgradable' to see them.
wazuhadmin@wazuhmanager:~$
```

4. Run the command to install curl: **sudo apt install curl**

```
wazuhadmin@wazuhmanager:~$ sudo apt install curl
Reading package lists... Done
Building dependency tree... Done
Reading state information... Done
curl is already the newest version (7.81.0-1ubuntu1.20).
curl set to manually installed.
0 upgraded, 0 newly installed, 0 to remove and 53 not upgraded.
wazuhadmin@wazuhmanager:~$
```

5. Install Wazuh by running the following command:

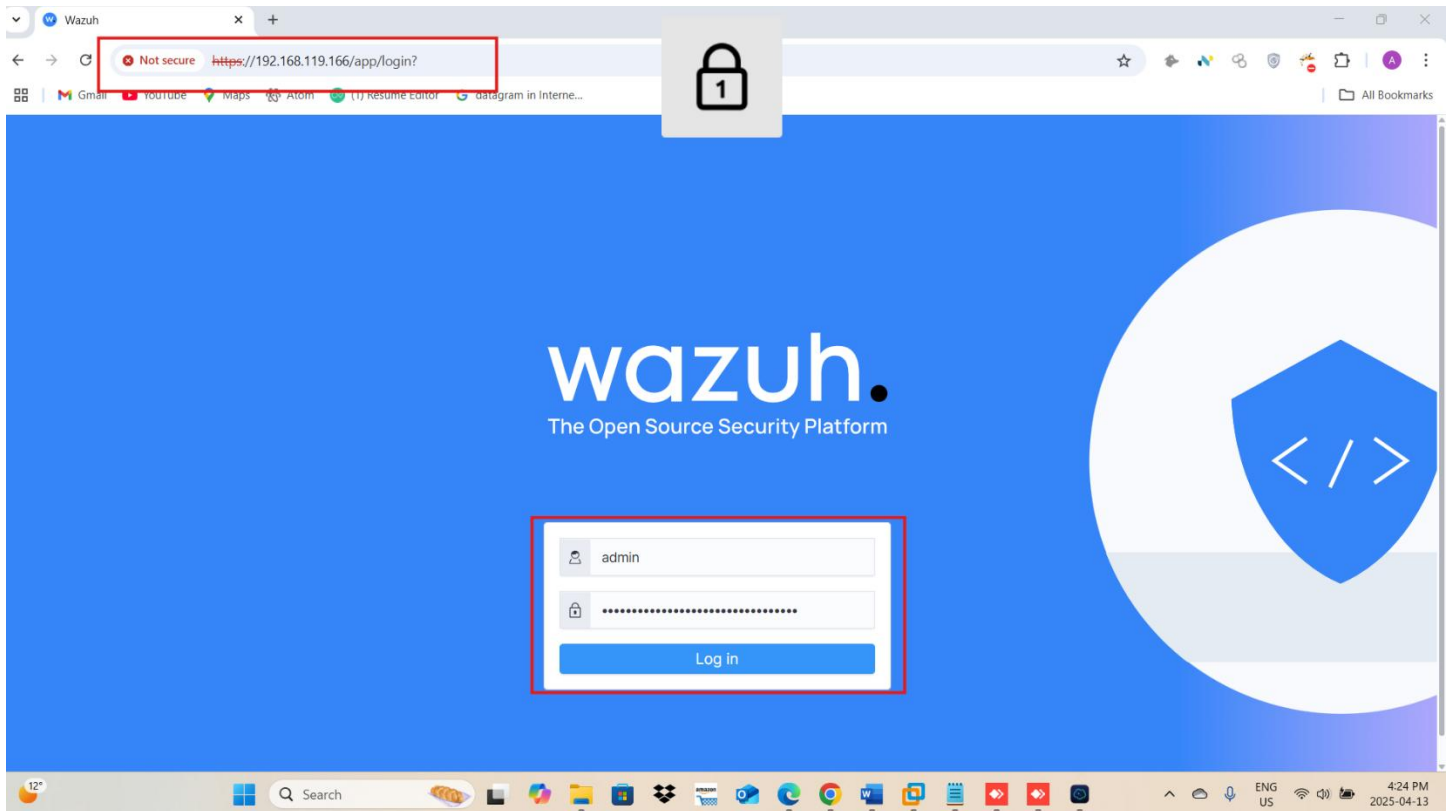
curl -sO https://packages.wazuh.com/4.7/wazuh-install.sh && sudo bash ./wazuh-install.sh -a

```
wazuhadmin@wazuhmanager:~$ curl -sO https://packages.wazuh.com/4.7/wazuh-install.sh && sudo bash ./wazuh-install.sh -a
13/04/2025 20:10:29 INFO: Starting Wazuh installation assistant. Wazuh version: 4.7.5
13/04/2025 20:10:34 INFO: Wazuh web interface port will be 443.
13/04/2025 20:10:37 INFO: --- Dependencies ---
13/04/2025 20:10:37 INFO: Installing apt-transport-https.
13/04/2025 20:10:43 INFO: Wazuh repository added.
13/04/2025 20:10:43 INFO: --- Configuration files ---
```

6. On the Windows VM, open a web browser and navigate to the Ubuntu server's IP address in the format:

`https://<ubuntu-server-ip>` Set up the Wazuh dashboard and create a username and password.

```
13/04/2025 20:17:17 INFO: Wazuh dashboard web application initialized
13/04/2025 20:17:17 INFO: --- Summary ---
13/04/2025 20:17:17 INFO: You can access the web interface https://<wazuh-dashboard-ip>:443
    User: admin
    Password: HDj2+jaJneB22MlvY8*tMYBAei0v4sKR
13/04/2025 20:17:17 INFO: Installation finished.
wazuhadmin@wazuhmanager:~$ ||
```



7. In the Wazuh dashboard, go to Management → Agents → Add agent. Select Windows and copy the two registration commands and add Server manager ip address.

The screenshot shows the 'Add agent' page in the Wazuh dashboard. The 'WINDOWS' package is selected under 'Select the package to download and install on your system:'. The 'Server address' field is filled with '192.168.119.166'.

The screenshot shows the 'Add agent' page in the Wazuh dashboard. The 'Invoke-WebRequest' command is highlighted in a red box. The 'Requirements' section lists the prerequisites for installation. The 'Start the agent' section shows the command to start the Wazuh service.

```
Invoke-WebRequest -Uri https://packages.wazuh.com/4.x/windows/wazuh-agent-4.7.5-1.msi -OutFile $(env:tmp)\wazuh-agent; msixec.exe /i $(env:tmp)\wazuh-agent /q WAZUH_MANAGER='192.168.119.166' WAZUH_AGENT_NAME='Wazuh_win10_agent' WAZUH_REGISTRATION_SERVER='192.168.119.166'
```

Requirements

- You will need administrator privileges to perform this installation.
- PowerShell 3.0 or greater is required.

Keep in mind you need to run this command in a Windows PowerShell terminal.

Start the agent:

```
NET START WazuhSvc
```

8. In the Windows VM, open PowerShell as Administrator and paste both registration commands.

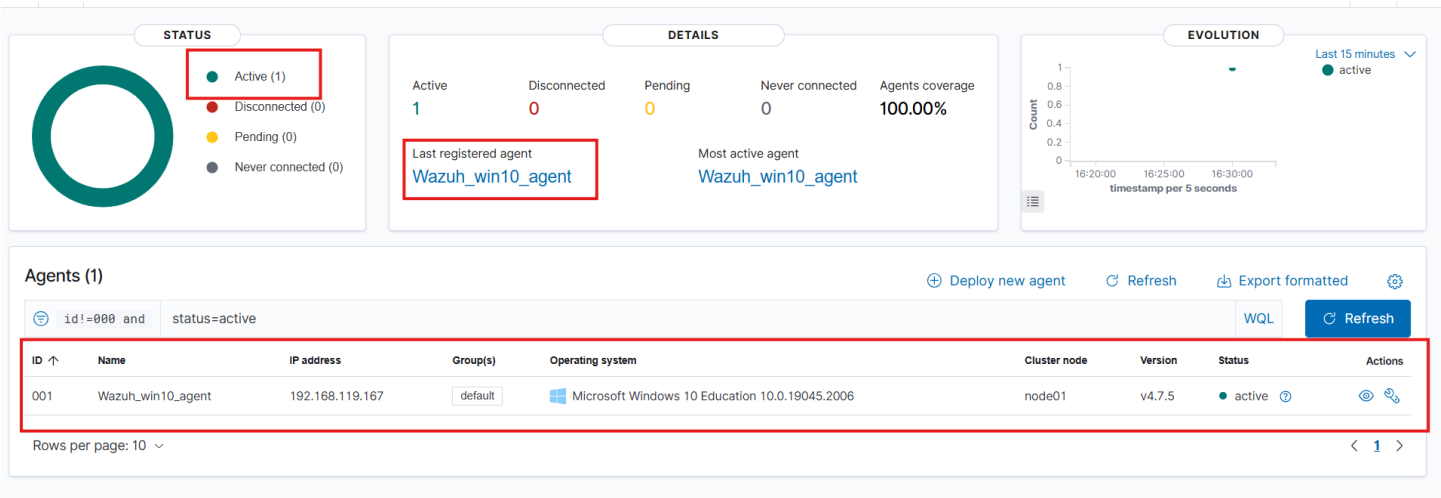
The screenshot shows a Windows PowerShell terminal window with the registration commands pasted into it.

```
Administrator: Windows PowerShell
PS C:\Windows\system32> Invoke-WebRequest -Uri https://packages.wazuh.com/4.x/windows/wazuh-agent-4.7.5-1.msi -OutFile $(env:tmp)\wazuh-agent; msixec.exe /i $(env:tmp)\wazuh-agent /q WAZUH_MANAGER='192.168.119.166' WAZUH_AGENT_NAME='Wazuh_win10_agent' WAZUH_REGISTRATION_SERVER='192.168.119.166'
PS C:\Windows\system32>
```

```

PS C:\Windows\system32> Invoke-WebRequest -Uri https://packages.wazuh.com/agents/windows/wazuh-win10-agent-4.7.5.exe
PS C:\Windows\system32> NET START WazuhSvc
The Wazuh service is starting.
The Wazuh service was started successfully.
PS C:\Windows\system32>
  
```

9. Confirm that the Windows agent is connected in the Wazuh dashboard.



10. Search **local_rules.xml** and add any custom rules if needed and save the file and Restart the Wazuh manager service on Wazuh dashboard then click on save button.

The screenshot shows the 'local_rules.xml' file in the Wazuh dashboard. The file contains two rules for detecting credential dumping. The 'Save' button is highlighted in the top right corner.

```

<local_rules.xml>
  1 <group name="windows,system,">
  2
  3 <rule id="504" level="5">
  4   <if_group>windows</if_group>
  5   <field name="win.eventdata.ruleName" type="pcre2">technique_id=T1003.006,technique_name=Dump Credential Manager using keymgr.dll and rundll32.exe</field>
  6   <description>!!!!!! ALERT !!!!!!! WIND_10_AGENT is being exploit using Credential Dumping (LSASS Memory Dump - T1003.001) $(win.system.computer)</description>
  7   <mitre>
  8     <id>T1003.006</id>
  9     <id>T1112</id>
  10  </mitre>
  11 </rule>
  12
  13 <rule id="750" level="5">
  14   <if_group>windows</if_group>
  15   <field name="win.eventdata.ruleName" type="pcre2">technique_id=T1003.006,technique_name=Dump Credential Manager using keymgr.dll and rundll32.exe</field>
  16   <description>!!!!!! ALERT !!!!!!! WIND_10_AGENT is being exploit using Credential Dumping (LSASS Memory Dump - T1003.001) $(win.system.computer)</description>
  17   <mitre>
  18     <id>T1003.006</id>
  19     <id>T1565.001</id>
  20     <id>T1112</id>
  21  </mitre>
  22 </rule>
  23 </group>
  24 </local_rules.xml>
  
```

11. On the Windows VM, open CMD as Administrator and run the following command:
notepad "C:\Program Files (x86)\ossec-agent\ossec.conf" Modify the configuration.

```
<localfile>
  <location>System</location>
  <log_format>eventchannel</log_format>
</localfile>

<localfile>
  <location>Microsoft-Windows-Sysmon/Operational</location>
  <log_format>eventchannel</log_format>
</localfile>

<localfile>
  <location>active-response\active-responses.log</location>
  <log_format>syslog</log_format>
</localfile>

<!-- Policy monitoring -->
<rootcheck>
  <disabled>no</disabled>
  <windows_apps>./shared/win_applications_rcl.txt</windows_apps>
  <windows_malware>./shared/win_malware_rcl.txt</windows_malware>
</rootcheck>

<!-- Security Configuration Assessment -->
<sca>
  <enabled>yes</enabled>
  .....
</sca>
```

12. Open PowerShell as Administrator and run the command: **Set-ExecutionPolicy Bypass -Scope CurrentUser**

```
PS C:\Windows\system32> Set-ExecutionPolicy Bypass -Scope CurrentUser
Execution Policy Change
The execution policy helps protect you from scripts that you do not trust. Changing the execution policy might expose you to the security risks described in the about_Execution_Policies help topic at
https://go.microsoft.com/fwlink/?LinkID=135170. Do you want to change the execution policy?
[Y] Yes [A] Yes to All [N] No [L] No to All [S] Suspend [?] Help (default is "N"): Y
PS C:\Windows\system32>
```

13. Add a Defender exclusion with the command: **Add-MpPreference -ExclusionPath C:\AtomicRedTeam**

```
the execution policy helps protect you from scripts that you do not trust. Changing the execution
https://go.microsoft.com/fwlink/?LinkID=135170. Do you want to change the execution policy?
[Y] Yes [A] Yes to All [N] No [L] No to All [S] Suspend [?] Help (default is "N"): Y
PS C:\Windows\system32> Add-MpPreference -ExclusionPath C:\AtomicRedTeam\
PS C:\Windows\system32>
```

14. Install the Atomic Red Team simulation tool using this command:

IEX (IWR 'https://raw.githubusercontent.com/redcanaryco/invoke-atomicredteam/master/install-atomicredteam.ps1' -UseBasicParsing); Install-AtomicRedTeam -getAtomics -Force

```
PS C:\Windows\system32> IEX (IWR 'https://raw.githubusercontent.com/redcanaryco/invoke-atomicredteam/master/install-atomicredteam.ps1' -UseBasicParsing); Install-AtomicRedTeam -getAtomics -Force
NuGet provider is required to continue
PowerShellGet requires NuGet provider version '2.8.5.201' or newer to interact with NuGet-based repositories. The NuGet provider must be available in 'C:\Program Files\PackageManagement\ProviderAssemblies' or
'C:\Users\abdullah\AppData\Local\PackageManagement\ProviderAssemblies'. You can also install the NuGet provider by running 'Install-PackageProvider -Name NuGet -MinimumVersion 2.8.5.201 -Force'. Do you want
PowerShellGet to install and import the NuGet provider now?
[Y] Yes [N] No [S] Suspend [?] Help (default is "Y"): Y
Installation of Invoke-AtomicRedTeam is complete. You can now use the Invoke-AtomicTest function
See Wiki at https://github.com/redcanaryco/invoke-atomicredteam/wiki for complete details
PS C:\Windows\system32>
```

15. Import the Atomic Red Team module using: **Import-Module "C:\AtomicRedTeam\invoke-atomicredteam\Invoke-AtomicRedTeam.ps1"**

```
[Y] Yes [N] No [S] Suspend [?] Help (default is "Y"): Y
Installation of Invoke-AtomicRedTeam is complete. You can now use the Invoke-AtomicTest function
See Wiki at https://github.com/redcanaryco/invoke-atomicredteam/wiki for complete details
PS C:\Windows\system32> Import-Module "C:\AtomicRedTeam\invoke-atomicredteam\Invoke-AtomicRedTeam.ps1"
PS C:\Windows\system32>
PS C:\Windows\system32>
```

16. To view a specific technique (T1003), run: **Invoke-AtomicTest T1003 -ShowDetailsBrief**

```
PS C:\Windows\system32>
PS C:\Windows\system32> Invoke-AtomicTest T1003 -ShowDetailsBrief
PathToAtomicsFolder = C:\AtomicRedTeam\atomics

T1003-1 Gsecdump
T1003-2 Credential Dumping with NPPSpy
T1003-3 Dump svchost.exe to gather RDP credentials
T1003-4 Retrieve Microsoft IIS Service Account Credentials Using AppCmd (using list)
T1003-5 Retrieve Microsoft IIS Service Account Credentials Using AppCmd (using config)
T1003-6 Dump Credential Manager using keymgr.dll and rundll32.exe
T1003-7 Send NTLM Hash with RPC Test Connection
PS C:\Windows\system32>
```

17. To simulate a credential dumping technique, run: **Invoke-AtomicTest T1003 -TestNumbers 6**

```
PS C:\Windows\system32>
PS C:\Windows\system32> Invoke-AtomicTest T1003 -ShowDetailsBrief
PathToAtomicsFolder = C:\AtomicRedTeam\atomics

T1003-1 Gsecdump
T1003-2 Credential Dumping with NPPSpy
T1003-3 Dump svchost.exe to gather RDP credentials
T1003-4 Retrieve Microsoft IIS Service Account Credentials Using AppCmd (using list)
T1003-5 Retrieve Microsoft IIS Service Account Credentials Using AppCmd (using config)
T1003-6 Dump Credential Manager using keymgr.dll and rundll32.exe
T1003-7 Send NTLM Hash with RPC Test Connection
PS C:\Windows\system32> Invoke-AtomicTest T1003 -TestNumbers 6
PathToAtomicsFolder = C:\AtomicRedTeam\atomics

Executing test: T1003-6 Dump Credential Manager using keymgr.dll and rundll32.exe
Exit code: 0
Done executing test: T1003-6 Dump Credential Manager using keymgr.dll and rundll32.exe
PS C:\Windows\system32>
```

18. Check logs on the Wazuh dashboard.

The screenshot displays the Wazuh Security events interface. At the top, a navigation bar includes 'Modules' and 'Security events'. A search bar is present with the text 'Search field names'. Below the search bar, there are filters for 'Filter by type' and 'Selected fields'. The 'Selected fields' section lists 'agent.name', 'rule.description', 'rule.id', and 'rule.level'. The 'Available fields' section lists various data sources like 'agent.id', 'agent.ip', 'data_extra_data', 'data.file', 'data.sca.check.compliance.cis', 'data.sca.check.compliance.cis_csc', 'data.sca.check.compliance.gdpr_IV', 'data.sca.check.compliance.gpg_13', 'data.sca.check.compliance.gpg13', 'data.sca.check.compliance.hipaa', and 'data.sca.check.compliance.nist_800_53'. The main content area shows a bar chart titled '974 hits' for the time range 'Apr 12, 2025 @ 17:29:04:107 - Apr 13, 2025 @ 17:29:04:107'. The chart shows a significant spike in hits at the end of the period. Below the chart is a table of alerts with columns: Time, agent name, rule description, rule level, and rule id. Two rows are highlighted with red boxes: one for rule 750 (Registry Value Integrity Checksum Changed) and one for rule 594 (Registry Key Integrity Checksum Changed).

Time	agent name	rule description	rule level	rule id
Apr 13, 2025 @ 17:25:49.972	Wazuh_win10_age nt	Registry Value Integrity Checksum Changed	5	750
Apr 13, 2025 @ 17:25:49.923	Wazuh_win10_age nt	Registry Value Integrity Checksum Changed	5	750
Apr 13, 2025 @ 17:25:49.908	Wazuh_win10_age nt	Registry Value Integrity Checksum Changed	5	750
Apr 13, 2025 @ 17:25:49.908	Wazuh_win10_age nt	Registry Key Integrity Checksum Changed	5	594
Apr 13, 2025 @ 17:25:49.908	Wazuh_win10_age nt	Registry Value Integrity Checksum Changed	5	750
Apr 13, 2025 @ 17:25:49.879	Wazuh_win10_age nt	Registry Key Integrity Checksum Changed	5	594

!!!!!!!!!!!!!! ALERT !!!!!!! WIND_10_AGENT is being exploit using Credential Dumping (LSASS Memory Dump - T1003.001) [win.system.computer](#)

[View alerts of this Rule](#)

750

5

local_rules.xml

etc/rules

Groups

windows, sysmon

> Details

> Compliance

∨ Related rules

ID ↑	Description	Groups	Compliance	Level	File
594	!!!!!!!!!!!!!! ALERT !!!!!!! WIND_10_AGENT is being exploit using Credential Dumping (LSASS Memory Dump - T1003.001) win.system.computer	windows, sysmon	MITRE	5	local_rules.xml
750	!!!!!!!!!!!!!! ALERT !!!!!!! WIND_10_AGENT is being exploit using Credential Dumping (LSASS Memory Dump - T1003.001) win.system.computer	windows, sysmon	MITRE	5	local_rules.xml

Rows per page: 10 ∨

< 1 >

!!!!!!!!!!!!!! ALERT !!!!!!!!! WIND_10_AGENT is being exploit using Credential Dumping
(LSASS Memory Dump - T1003.001) [win.system.computer](#)

[View alerts of this Rule](#)



Information

ID	Level	File	Path
750	5	local_rules.xml	etc/rules

Groups

[windows](#), [sysmon](#)

Details

If_group

windows

Win.Eventdata.RuleName

pattern: technique_id=T1003.006,technique_name=Dump
Credential Manager using
keymgr.dll and rundll32.exe,
type: pcre2

Compliance

Mitigation Strategies

- Use Windows Defender Credential Guard to isolate LSASS in a secure, virtualized environment, preventing tools from accessing LSASS memory and dumping credentials.
- Create rules in AppLocker or Windows Defender Application Control to block or limit the execution of rundll32.exe from running untrusted or user-space DLLs that can trigger credential dumping.
- Ensure users operate with standard privileges and only receive administrative rights when necessary, reducing the chances of malicious scripts or binaries accessing LSASS.
- Use Group Policy to restrict LSASS access and apply registry settings such as disabling WDigest credential.
- Set the system to disable full memory dumps by configuring the CrashDumpEnabled registry value to 0, minimizing the risk of attackers dumping sensitive memory contents.
- Use SIEM or EDR solutions to detect rundll32.exe launching unusual or non-standard DLLs (especially from C:\Users\, AppData\, or Temp folders), and generate alerts on anomalous patterns.
- Configure audit policies to log command-line arguments (Event ID 4688) for all process creations, allowing detection of command-line-based credential dumping techniques.
- Enable Windows Exploit Protection settings for lsass.exe to reduce its exposure to memory manipulation and dumping.
- Ensure systems are up to date with the latest Windows security patches, especially updates that address LSASS protection and memory security improvements.
- Set up signatures, rule-based detections, or behavioral analysis in your SIEM to catch known credential dumping tools by Mimikatz.

Summary:

This project provides hands-on experience with setting up and configuring a SIEM environment, which is crucial for monitoring and defending against cyber threats. It emphasizes the importance of proactive threat detection, the process of simulating real-world attacks to identify vulnerabilities, and how to fine-tune detection systems to improve their effectiveness.

Key learnings include:

- Setting up a SIEM environment and configuring Wazuh as a threat detection platform.
- Understanding and simulating Credential Dumping (T1003.001).
- Implementing attack simulations using the MITRE ATT&CK framework.
- Analyzing SIEM alerts and identifying detection gaps that need further tuning or improvement.

References:

- Wazuh. (n.d.). *Wazuh virtual machine deployment options*. Wazuh Documentation. Retrieved March 10, 2025, from <https://documentation.wazuh.com/current/deployment-options/virtual-machine/virtual-machine.html>
- Microsoft. (n.d.). *Download Windows 11*. Microsoft. Retrieved March 10, 2025, from <https://www.microsoft.com/en-ca/software-download/windows11>
- Wazuh. (n.d.). *Wazuh agent installation guide*. Wazuh Documentation. Retrieved March 10, 2025, from <https://documentation.wazuh.com/current/installation-guide/wazuh-agent/index.html>
- Red Canary. (n.d.). *Invoke-AtomicRedTeam wiki*. GitHub. Retrieved March 10, 2025, from <https://github.com/redcanaryco/invoke-atomicredteam/wiki>
- Red Canary. (n.d.). *Execute atomic tests (Local)*. GitHub. Retrieved March 10, 2025, from [https://github.com/redcanaryco/invoke-atomicredteam/wiki/Execute-Atomic-Tests-\(Local\)](https://github.com/redcanaryco/invoke-atomicredteam/wiki/Execute-Atomic-Tests-(Local))
- MITRE Corporation. (n.d.). *MITRE ATT&CK framework*. MITRE. Retrieved March 10, 2025, from <https://attack.mitre.org/>